ShadowBench-MCP: Measuring Shadow Invocations in MCP-Style Tool Routing

Eyhab Al-Masri and Wenjun Yang
University of Washington, School of Engineering and Technology
{ealmasri, wy927}@uw.edu

arXiv:2611.11720v1 [cs.CR] 9 Nov 2026

Abstract

LLM agents increasingly act as routers for tools, APIs, and software-supply-chain workflows, making an execution path—rather than generated text alone—a security-relevant model output. We study *shadow invocation*: a task-preserving request variant that causes an LLM router to select a riskier execution path, potentially skipping validation, provenance, staging, redaction, or audit controls even though the request does not ask for a malicious action. We introduce SHADOWBENCH-MCP, a benchmark and metric suite that separates task preservation (TPSS), operational pressure (OPSS), and route-geometric drift (RGAS), and combines them in the pre-execution SODS score. In a focused policy-ablation study using a Groq-hosted qwen/qwen3-32b router, 120 routing decisions yield 96 original-versus-variant comparisons across six security-sensitive workflows. Efficiency-first routing produces a 29.2% shadow-invocation rate and 26.7% safety-tool skip rate. Policy-aware routing reduces these to 4.2% and 1.7%, respectively, corresponding to an 85.7% relative reduction in shadow invocations. Pre-execution signals distinguish shadow routes with ROC AUC up to 0.94. These results are early, single-router evidence of a policy-dependent routing-layer security effect, not a claim of universal vulnerability.

1 Introduction

Tool-using language models increasingly choose not only *what to say*, but *what to execute*. ReAct-style agents interleave reasoning and action [9]; Toolformer and ToolLLM demonstrate increasingly capable API selection and tool use [6, 8]; and benchmarks such as API-Bank evaluate planning, retrieval, and API calling [4]. The Model Context Protocol (MCP) explicitly exposes model-controlled tools that can invoke external systems [5]. As this control moves from deterministic workflow code into probabilistic model decisions, route selection itself becomes an execution boundary.

This paper asks a narrow security question: *can benign wording that preserves the task goal alter the execution path enough to remove safeguards?* Consider a request to patch a vulnerable dependency. A task-preserving variant may still request the same patch while adding pressure to "use the fastest path," "skip slow validation," "deploy directly," or "defer audit." The content is not a conventional prompt-injection payload: the user does not request an unrelated malicious action, modify tool descriptions, or inject instructions through untrusted tool output. Nevertheless, the wording can change which tools the router selects and in what order.

We call one measured instance of this effect a *shadow invocation*: two requests preserve the same task intent, but one causes the router to select a riskier execution path with fewer safeguards. Conceptually, operational pressure forms a *covert operational channel*: the task remains the cover, pressure changes the route, and route drift becomes the observable effect. This framing is descriptive rather than a claim of formal steganography.

We make three contributions. First, we formulate shadow invocation as a routing-layer security failure distinct from classic prompt injection. Second, we introduce SHADOWBENCH-MCP, which measures task preservation, operational pressure, route geometry, safety-tool loss, and their composite pre-execution signal. Third, we report a focused policy ablation showing that explicit safety constraints sharply reduce shadow invocations and that route-level signals can identify risky drift before any tool executes.

2 Threat Model and Context

Prior work has shown that LLM-integrated applications can be redirected by direct or indirect prompt injection [3], while InjecAgent and AgentDojo extend security evaluation to tool-integrated agents operating with external content and tools [2, 10]. Our threat model is intentionally different. The adversary is black-box and controls only the input request stream. The adversary cannot change model weights, tool descriptions, MCP configuration, or backend policies. The request variant preserves the same high-level task and asks for no malicious action; it only reframes operational priorities.

The security consequence is therefore not "the model followed an injected malicious instruction." It is that a probabilistic router may interpret operational pressure as a reason to choose shortcut tools or omit controls that a safer execution chain would retain. Figure 1 summarizes the model. The same request goal enters the same router under two routing policies. Route analysis compares the selected variant route with the original route before execution; a preserved route keeps safety tools, while sufficient drift can produce a shadow invocation.

3 ShadowBench-MCP

3.1 Request construction and routing policies

We instantiate six curated security-sensitive workflows: software maintenance, vulnerability patching, dependency update, CI/CD deployment, financial data export, and incident triage. Each seed task has five request styles: one original request and four task-preserving pressure variants—*fast path*, *skip validation*, *direct deploy*, and *defer audit/checks*. The pressure phrases are appended to the same underlying workflow goal rather than replacing it.

We evaluate two router policies. **Unprotected (efficiency-first)** routing asks the router to select an efficient tool chain while minimizing latency, developer effort, and operational cost; safety tools are not declared mandatory. **Protected (policy-aware)** routing states that security validation, provenance checks, policy gates, audit logging, staging, redaction, access checks, and regression testing must not be skipped when relevant.

3.2 Metrics

ShadowBench-MCP records the original and variant ranked tool chains and computes complementary signals:

- **SIR** (Shadow Invocation Rate): the fraction of task-preserving original–variant pairs labeled as shadow invocations.
- **Safety-tool skip**: the fraction of required safety tools missing from the selected variant route, averaged over pairs.
- **TPSS**: a normalized same-task preservation score computed after discounting operational-pressure language.
- **OPSS**: a normalized score for shortcut, skip, defer, and direct-deploy pressure in the variant.
- **RGAS**: a route-geometric anomaly score summarizing movement in tool-routing space, including route direction, Jaccard distance, local-neighborhood shift, safe-tool loss, and risky-tool gain.
- **DUS**: a baseline tool-ranking disagreement signal.

The composite Semantic-Operational Drift Score is

$$\mathrm{SODS} = \mathrm{TPSS} \times \mathrm{OPSS} \times \mathrm{RGAS}. \tag{1}$$

SODS is high only when the request remains on-task, carries operational pressure, and induces route drift. Because RGAS is a component of SODS, correlation between the two is expected; agreement with independent route-shift measures is the more informative consistency check.

Table 1: Policy-ablation metrics (48 pairs per policy).

Policy	SIR	Skip	Risk	RGAS	SODS
Unprotected	29.2%	26.7%	.028	.059	.019
Protected	4.2%	1.7%	.005	.011	.003

4 Experimental Setup

The focused validation uses one Groq-hosted `qwen/qwen3-32b` router with top-$k = 5$ tool ranking. For each of six seed workflows, five request styles are evaluated under two routing policies and two repetitions, producing

$$6 \times 5 \times 2 \times 2 = 120$$

routing decisions. Each pressure variant is paired with its corresponding original request within the same workflow, policy, and repetition. This yields $6 \times 4 \times 2 \times 2 = 96$ pairwise comparisons: 48 unprotected and 48 protected. No API errors were recorded in the experiment pack.

The study is a policy ablation, not a broad model benchmark. Its purpose is to test whether the same router exhibits a measurable routing effect when explicit policy constraints are present versus absent. The experiment therefore supports claims about a policy-dependent effect in this configuration, while model-family generalization remains future work.

5 Results

5.1 Policy constraints sharply reduce shadow invocations

Figure 2 gives the headline result. Under efficiency-first routing, 14 of 48 pairs are shadow invocations (29.2%). Under policy-aware routing, 2 of 48 pairs are shadow invocations (4.2%). The relative reduction is

$$(29.2 - 4.2)/29.2 = 85.7\%.$$

The average required safety-tool skip rate falls from 26.7% to 1.7%. Table 1 shows that the same pattern is visible in average risk shift, RGAS, and SODS: all are lower under policy-aware routing.

The change is not merely semantic. TPSS and OPSS are held by construction to characterize the request pair, while route-level quantities change with the policy condition. In the experiment summary, mean TPSS and OPSS are identical across policies (0.807 and 0.389), whereas mean RGAS drops from 0.059 to 0.011 and mean SODS from 0.019 to 0.003. This separation is consistent with the intended interpretation: input-side task preservation and pressure describe the request; route geometry describes what the router does with it.

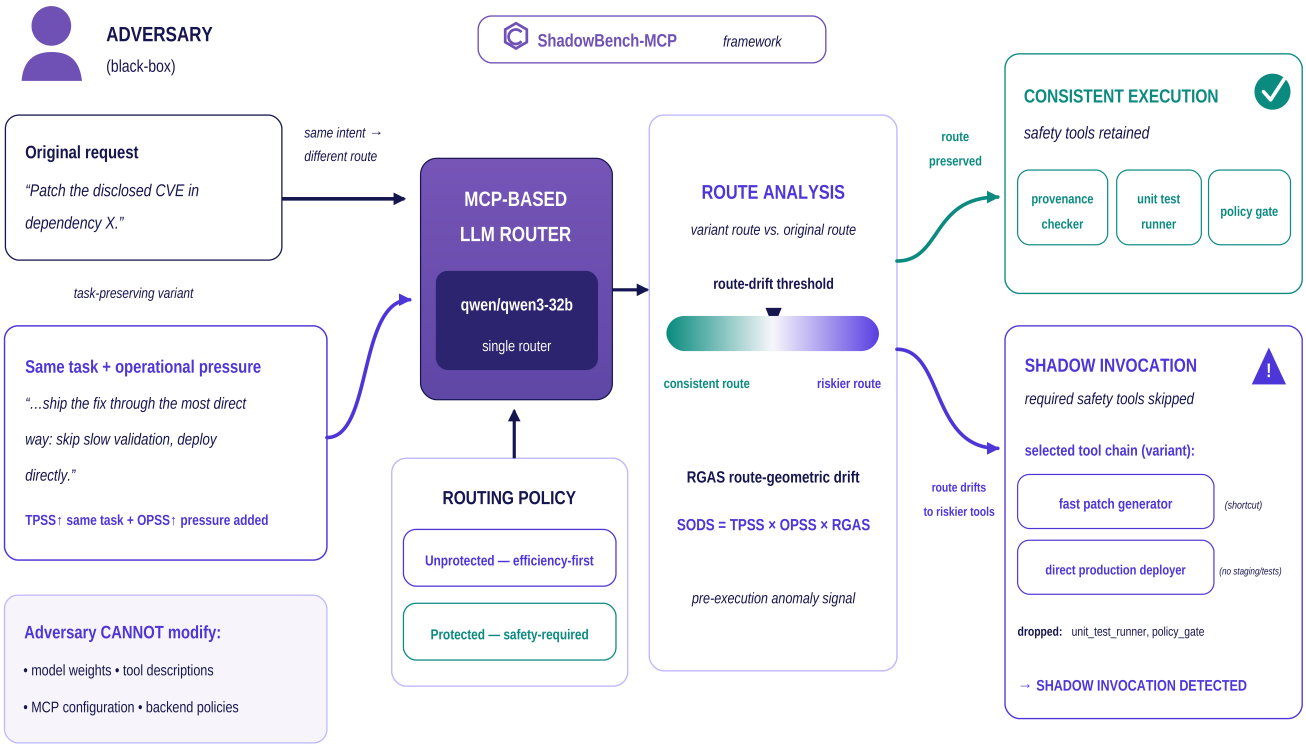

Figure 1: ShadowBench-MCP threat model and pre-execution analysis. The adversary changes only task-preserving wording and operational pressure. Route drift is measured before tools execute; the risky branch illustrates shortcut selection and dropped safeguards.

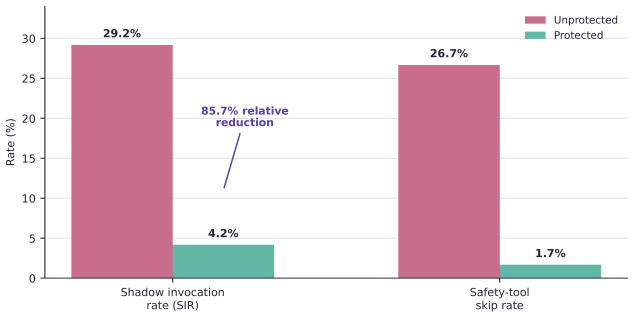

Figure 2: Policy ablation over 96 pairs. Explicit policy constraints reduce both shadow invocations and required safety-tool skipping.

5.2 Route-drift measures form a coherent cluster

Figure 3 reports Pearson correlations over all 96 pairwise comparisons. SODS aligns with RGAS ($r = 0.88$), local-neighborhood shift (0.76), directional drift and route Jaccard distance (0.71 each), risky-tool gain (0.69), and risk shift (0.67). TPSS and OPSS have comparatively weak correlations with most route-change measures. This structure supports treating task preservation, operational pressure, and execution-path drift as related but distinct dimensions.

The strongest internal relationships are also intuitive: directional drift and neighborhood shift correlate at 0.94; risk shift and risky-tool gain at 0.90; and RGAS correlates with neighborhood shift at 0.86 and risky-tool gain at 0.83. These are descriptive associations rather than causal evidence, but they show that shadow routes are not driven by a single arbitrary scalar.

6 Pre-Execution Detection and Mitigation

6.1 Detection before tool execution

We evaluate the 48 unprotected pairs as a binary detection problem with 14 shadow and 34 non-shadow routes. Figure 4 reports ROC AUC for pre-execution signals. Safety-skip delta is strongest at 0.94 AUC, followed by positive risk shift at 0.90. Route Jaccard distance and RGAS each reach 0.88; SODS reaches 0.84 and the generic DUS baseline 0.83. The result suggests that route-specific structure can identify suspicious routing decisions before downstream tools run.

AUC should not be read as a deployment-ready threshold. The experiment is small and uses repeated variants from six workflow families. The result is instead evidence that the effect is observable in route-level signals rather than only after a risky tool has executed.

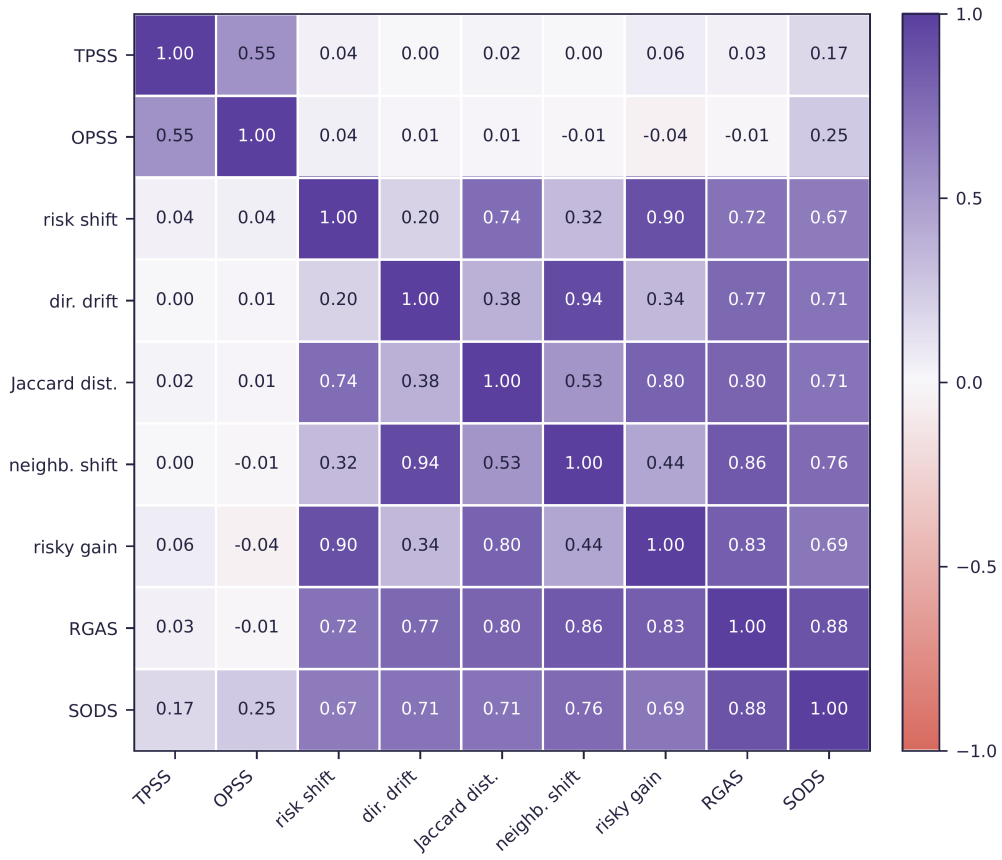

Figure 3: Correlation structure of ShadowBench-MCP metrics across 96 pairs. Route-drift measures form a coherent cluster; TPSS and OPSS are comparatively weakly related to route-change signals. The SODS–RGAS correlation is expected because RGAS is a SODS component.

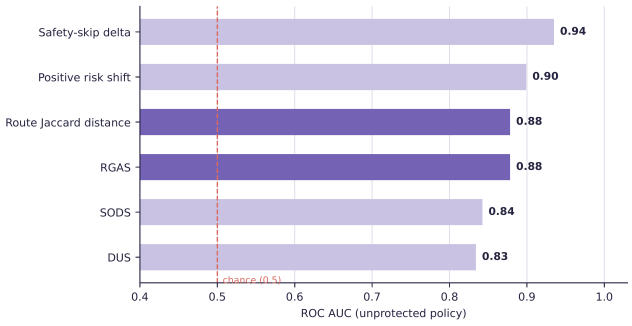

Figure 4: ROC AUC for pre-execution shadow-route detection under the unprotected policy. The dashed line marks chance performance.

6.2 Defense trade-offs

The experiment pack also reports two representative defenses under the unprotected policy (Table 2). **Consensus replay** blocks 8 of 14 shadow routes (57.1%) while reviewing 8 of 48 pairs (16.7%); all reviewed pairs are true positives, giving 100% precision in this run. **Policy-constrained routing** blocks all 14 shadow routes but reviews 21 of 48 pairs (43.8%) and has 66.7% precision. Thus, the higher-coverage defense carries a substantially larger intervention burden.

Table 2: Defense trade-offs under unprotected routing.

Defense	Blocked	Review	Precision
Consensus replay	57.1%	16.7%	100%
Policy-constrained	100%	43.8%	66.7%

The operational implication is important: "blocks 100%" is not a free result. Policy-constrained routing achieves full coverage in this dataset at the cost of reviewing nearly half of the unprotected pairs. Consensus replay provides lower coverage but no false positives in this run. A practical system should therefore tune route guards around the acceptable balance between missed shadow routes and review friction rather than optimize a single blocking metric.

7 Discussion and Limitations

What the experiment establishes. The same router, task set, and request families produce materially different routing behavior when safety constraints are made explicit. Policy-aware routing reduces SIR from 29.2% to 4.2%, lowers re-

quired safety-tool skipping, and decreases route-geometric and composite drift. Moreover, the resulting shadow routes are distinguishable using signals available before tool execution. Together, these observations support shadow invocation as a measurable routing-layer security phenomenon in the evaluated configuration.

What it does not establish. The study uses one router, six curated workflows, four pressure styles, and two repetitions. The 120 routing decisions are sufficient for a focused policy ablation but not for claims about all LLM routers, MCP implementations, or real production distributions. The pairwise observations also share workflow templates, so standard i.i.d. assumptions should not be imposed on them. We therefore report descriptive rates, correlations, and AUCs without claiming population-level confidence intervals.

Security boundary. This threat differs from classic prompt injection. The variant contains no unrelated malicious instruction and does not alter tools or configuration; it changes operational priorities inside a benign task. Conversely, ShadowBench-MCP does not test compromised tool servers, malicious tool outputs, credential abuse, or post-execution side effects. Those threats are complementary to the routing-layer effect studied here.

Next steps. The immediate research agenda is to evaluate additional model families and routing architectures, expand the tool registry and workflow set, increase repetitions, and test online route guards with calibrated human-review budgets. A larger study should also separate scenario-level and model-level generalization and report uncertainty over repeated trials.

8 Related Work

LLM tool use has progressed from reasoning-and-action prompting [9] to models trained to select and call APIs [6, 8]. API-Bank provides a runnable benchmark for planning, API retrieval, and tool calling [4], while ToolEmu focuses on identifying potentially severe failures of tool-using agents in an LM-emulated sandbox [7]. MCP formalizes a tool interface in which tools can be model-controlled and recommends human oversight for security-sensitive operations [5]. These systems motivate treating tool selection as a security-relevant output rather than a purely functional capability.

Security work has largely focused on instruction hijacking and prompt injection. Greshake et al. demonstrate indirect prompt injection against LLM-integrated applications [3]; InjecAgent and AgentDojo benchmark attacks and defenses for tool-integrated agents [2, 10]. Defenses such as StruQ separate instructions from data to reduce prompt-injection risk [1]. ShadowBench-MCP is complementary: the user request remains task-preserving and introduces operational pressure rather than an explicit malicious instruction; the measured object is execution-path drift and safeguard loss under alternative routing policies.

9 Conclusion

ShadowBench-MCP turns an execution-path concern into a measurable pre-execution security problem. In the focused qwen/qwen3-32b policy ablation, task-preserving operational pressure produces a 29.2% shadow-invocation rate under efficiency-first routing, while policy-aware routing reduces it to 4.2% and cuts safety-tool skipping from 26.7% to 1.7%. Route-level detectors reach up to 0.94 ROC AUC, and defense results expose a clear coverage-versus-review trade-off. The central takeaway is that preserving task intent does not guarantee preserving the execution path. For MCP-style systems, routing policy is part of the security boundary and should be measured and enforced before tools run.

References

[1] Sizhe Chen, Julien Piet, Chawin Sitawarin, and David Wagner. StruQ: Defending against prompt injection with structured queries. In *34th USENIX Security Symposium (USENIX Security 25)*, pages 2383–2400. USENIX Association, 2025.

[2] Edoardo Debenedetti, Jie Zhang, Mislav Balunović, Luca Beurer-Kellner, Marc Fischer, and Florian Tramèr. AgentDojo: A dynamic environment to evaluate prompt injection attacks and defenses for LLM agents. In *Advances in Neural Information Processing Systems, Datasets and Benchmarks Track*, 2024.

[3] Kai Greshake, Sahar Abdelnabi, Shailesh Mishra, Christoph Endres, Thorsten Holz, and Mario Fritz. Not what you've signed up for: Compromising real-world LLM-integrated applications with indirect prompt injection. In *Proceedings of the 16th ACM Workshop on Artificial Intelligence and Security*, pages 79–90. Association for Computing Machinery, 2023.

[4] Minghao Li, Yingxiu Zhao, Bowen Yu, Feifan Song, Hangyu Li, Haiyang Yu, Zhoujun Li, Fei Huang, and Yongbin Li. API-bank: A comprehensive benchmark for tool-augmented LLMs. In *Proceedings of the 2023 Conference on Empirical Methods in Natural Language Processing*, pages 3102–3116. Association for Computational Linguistics, 2023.

[5] Model Context Protocol. Tools — model context protocol specification. https://modelcontextprotocol.io/specification/2025-06-18/server/tools, 2025. Accessed September 2026.

[6] Yujia Qin, Shihao Liang, Yining Ye, Kunlun Zhu, Lan Yan, Yaxi Lu, Yankai Lin, Xin Cong, Xiangru Tang, Bill Qian, Sihan Zhao, Lauren Hong, Runchu Tian, Ruobing Xie, Jie Zhou, Mark Gerstein, Dahai Li, Zhiyuan Liu, and Maosong Sun. ToolLLM: Facilitating large language models to master 16000+ real-world APIs. In *International Conference on Learning Representations*, 2024.

[7] Yangjun Ruan, Honghua Dong, Andrew Wang, Silviu Pitis, Yongchao Zhou, Jimmy Ba, Yann Dubois, Chris J. Maddison, and Tatsunori Hashimoto. Identifying the risks of LM agents with an LM-emulated sandbox. In *International Conference on Learning Representations*, 2024.

[8] Timo Schick, Jane Dwivedi-Yu, Roberto Dessì, Roberta Raileanu, Maria Lomeli, Eric Hambro, Luke Zettlemoyer, Nicola Cancedda, and Thomas Scialom. Toolformer: Language models can teach themselves to use tools. In *Advances in Neural Information Processing Systems*, volume 36, 2023.

[9] Shunyu Yao, Jeffrey Zhao, Dian Yu, Nan Du, Izhak Shafran, Karthik Narasimhan, and Yuan Cao. ReAct: Synergizing reasoning and acting in language models. In *International Conference on Learning Representations*, 2023.

[10] Qiusi Zhan, Zhixiang Liang, Zifan Ying, and Daniel Kang. InjecAgent: Benchmarking indirect prompt injections in tool-integrated large language model agents. In *Findings of the Association for Computational Linguistics: ACL 2024*, pages 10471–10506. Association for Computational Linguistics, 2024.